

Marco integrativo GQM + PRAGMATIC para indicadores STRIDE

1. Introducción

Este documento integra la metodología Goal-Question-Metric (GQM) con los criterios PRAGMATIC para diseñar y evaluar indicadores derivados del modelo STRIDE a nivel nacional y organizativo.

Se toma como referencia el conjunto de indicadores ilustrativos definidos en el informe STRIDE previo (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service y Elevation of Privilege), y se estructura cada uno siguiendo la cadena:

Objetivo (Goal) – Pregunta (Question) – Métrica (Metric), evaluando la calidad de cada métrica según los nueve criterios PRAGMATIC: Predictiva, Relevante, Accionable, Genuina, Significativa, Precisa, Oportuna, Independiente y Rentable.

2. Objetivos nacionales y organizativos (G de GQM)

2.1. Objetivos nacionales (nivel España)

G-N-1: Reducir la frecuencia y el impacto de incidentes de suplantación de identidad (Spoofing) en servicios esenciales regulados por NIS2.

G-N-2: Reducir la probabilidad de manipulación no autorizada de datos y configuraciones críticas (Tampering) en infraestructuras esenciales.

G-N-3: Garantizar la trazabilidad suficiente para atribuir incidentes y cumplir obligaciones de notificación (Repudiation).

G-N-4: Disminuir la exposición de información sensible (Information Disclosure) en sistemas y servicios críticos.

G-N-5: Aumentar la resiliencia frente a la denegación de servicio (DoS) en servicios esenciales.

G-N-6: Reducir las oportunidades de escalada de privilegios (Elevation of Privilege), especialmente en cuentas e identidades privilegiadas.

2.2. Objetivos organizativos (nivel empresa/entidad)

Se alinean con los objetivos nacionales, pero concretados a la organización:

G-O-S: Minimizar la superficie de suplantación de identidades de usuarios y servicios críticos.

G-O-T: Asegurar la integridad de datos y configuraciones relevantes mediante controles técnicos y organizativos robustos.

G-O-R: Mantener registros suficientes, íntegros y utilizables para reconstruir incidentes y atribuir acciones.

G-O-I: Proteger la confidencialidad de los datos sensibles en tránsito, en reposo y en procesos externos (cloud, terceros, IA).

G-O-D: Mantener la disponibilidad de servicios críticos dentro de los SLA acordados, incluso bajo ataques o fallos.

G-O-E: Gobernar las identidades privilegiadas y aplicar mínimo privilegio de forma verificable.

3. Preguntas y métricas por categoría STRIDE (Q y M de GQM)

En las tablas siguientes se definen preguntas (Q) y métricas (M) para cada objetivo organizativo, con breve definición técnica.

3.1. Spoofing (S)

Objetivo G-O-S: Minimizar la superficie de suplantación de identidades de usuarios y servicios críticos.

ID	Pregunta (Q)	Métrica (M)	Definición técnica básica
S1	¿En qué medida están protegidos con MFA los accesos a sistemas críticos?	% de accesos críticos protegidos con MFA	Nº de cuentas con MFA habilitada sobre el total de cuentas con acceso a sistemas críticos.
S2	¿Cómo de gestionadas están las identidades privilegiadas frente a suplantación?	% de cuentas privilegiadas bajo PAM con MFA	Nº de cuentas privilegiadas gestionadas en PAM y con MFA / total de cuentas privilegiadas.
S3	¿Cuál es la calidad de autenticación en APIs y servicios M2M críticos?	% de APIs críticas con autenticación fuerte	Nº de APIs críticas que usan tokens firmados, mTLS u otros esquemas fuertes / total de APIs críticas.
S4	¿Qué capacidad tiene la organización para detectar intentos de suplantación?	Tasa de intentos de suplantación detectados por 1.000 usuarios/mes	Nº de eventos de login sospechoso, credenciales robadas, etc., registrados y analizados / (usuarios activos/1.000).

3.2. Tampering (T)

Objetivo G-O-T: Asegurar la integridad de datos y configuraciones relevantes.

ID	Pregunta (Q)	Métrica (M)	Definición técnica básica
T1	¿En qué medida se protege la integridad de logs y datos críticos?	% de sistemas críticos con logs/datos protegidos criptográficamente	Nº de sistemas críticos con mecanismos de integridad (hashes, WORM, etc.) / total de sistemas críticos.
T2	¿Cuál es el grado de control sobre la capacidad de modificar datos de negocio?	% de procesos críticos con doble control / segregación de funciones	Nº de procesos críticos con doble aprobación o SoD / total de procesos críticos identificados.
T3	¿Qué nivel de garantías de integridad tienen los dispositivos IoT/OT?	% de dispositivos críticos con firmware firmado y arranque seguro	Nº de dispositivos OT/IoT críticos con dichas capacidades / total de dispositivos críticos.

3.3. Repudiation (R)

Objetivo G-O-R: Mantener registros suficientes e íntegros para reconstruir incidentes.

ID	Pregunta (Q)	Métrica (M)	Definición técnica básica
R1	¿Cuál es la cobertura de logging detallado en sistemas críticos?	% de sistemas críticos con logging centralizado y completo	Nº de sistemas críticos integrados en SIEM con logging detallado / total de sistemas críticos.
R2	¿Hasta qué punto se garantiza la inmutabilidad y retención adecuada de logs?	% de logs críticos almacenados en soportes inmutables	Volumen de logs críticos en WORM, almacenamiento con retención legal, etc. / volumen total de logs críticos.
R3	¿Cuán capaz es la organización de reconstruir eventos de seguridad?	Tiempo medio para reconstruir un incidente (TMR)	Tiempo desde la detección hasta la reconstrucción suficientemente detallada del incidente en ejercicios/pruebas.

3.4. Information Disclosure (I)

Objetivo G-O-I: Proteger la confidencialidad de datos sensibles.

ID	Pregunta (Q)	Métrica (M)	Definición técnica básica
I1	¿Existe un inventario y clasificación adecuados de datos sensibles?	% de activos de información clasificados	Nº de activos de información con clasificación formal / total de activos inventariados.
I2	¿En qué medida se cifra la información sensible en reposo?	% de datos sensibles cifrados en reposo	Volumen de datos clasificados como sensibles cifrados en reposo / volumen total de datos sensibles.
I3	¿Qué nivel de protección en tránsito tienen los servicios críticos?	% de flujos de red críticos bajo TLS fuerte	Nº de flujos clasificados como críticos y cifrados con TLS conforme a política / total de flujos críticos.
I4	¿Se gestionan adecuadamente los riesgos en integraciones con terceros y cloud?	% de integraciones críticas con evaluación de riesgo completada	Nº de integraciones críticas con evaluación formal de riesgo y controles aceptados / total de integraciones críticas.

3.5. Denial of Service (D)

Objetivo G-O-D: Mantener la disponibilidad de servicios críticos.

ID	Pregunta (Q)	Métrica (M)	Definición técnica básica
D1	¿Se mide adecuadamente la disponibilidad de servicios críticos?	Horas de indisponibilidad anual por servicio crítico	Suma de periodos de indisponibilidad no planificada por servicio en 12 meses.
D2	¿Qué grado de protección frente a DoS tienen los servicios externos?	% de servicios externos críticos con protección DoS/DDoS	Nº de servicios externos críticos con WAF, CDN, DDoS protection, etc. / total de servicios externos críticos.
D3	¿Qué nivel de preparación existe en continuidad de negocio?	% de servicios esenciales con planes de continuidad probados	Nº de servicios esenciales con planes probados en los últimos 12-24 meses / total de servicios esenciales.
D4	¿Cuál es la resiliencia de las propias capacidades de seguridad ante DoS?	% de herramientas de seguridad con arquitectura redundante	Nº de componentes SOC (SIEM, SOAR, etc.) con redundancia y pruebas documentadas / total de componentes clave.

3.6. Elevation of Privilege (E)

Objetivo G-O-E: Gobernar las identidades privilegiadas.

ID	Pregunta (Q)	Métrica (M)	Definición técnica básica
E1	¿Qué grado de gestión centralizada existe para cuentas privilegiadas?	% de cuentas privilegiadas bajo PAM	Nº de cuentas privilegiadas gestionadas bajo PAM / total de cuentas privilegiadas.
E2	¿Se aplica el principio de mínimo privilegio?	% de roles/perfiles revisados anualmente	Nº de roles/perfiles críticos revisados y ajustados en el último año / total de roles/perfiles críticos.
E3	¿Se revisan y auditan permisos privilegiados de forma sistemática?	Nº de revisiones de permisos privilegiados/año	Número de revisiones formales completadas por año natural.
E4	¿Cuál es el grado de segregación de funciones?	% de funciones críticas con segregación definida	Nº de funciones críticas con SoD documentada y aplicada / total de funciones críticas.

3.7. Gobierno y métricas (GOV / MET)

Aunque no sean categorías STRIDE en sentido estricto, son necesarias para cerrar el ciclo GQM.

ID	Pregunta (Q)	Métrica (M)	Definición técnica básica
G1	¿Existe un proceso formal y repetible de threat modeling?	Nivel de formalización (0-3)	Escala: 0=inexistente, 1=informal, 2=definido, 3=definido+medido.
G2	¿Qué grado de implantación tiene STRIDE como lenguaje común?	% de proyectos críticos con threat modeling STRIDE	Nº de proyectos críticos que usan STRIDE / total de proyectos críticos.
M1	¿Se dispone de un cuadro de mando de seguridad alineado con STRIDE?	Índice de cobertura de métricas STRIDE (0-1)	Nº de métricas STRIDE implantadas / Nº de métricas STRIDE definidas como objetivo.
M2	¿Se utilizan métricas en la toma de decisiones?	Nº de decisiones de inversión justificadas por métricas/año	Número de decisiones de inversión o priorización respaldadas por métricas formales.

4. PRAGMATIC: criterios de evaluación de cada métrica

Para cada métrica definida se evaluará, en una escala 0–3, su nivel de:

- Predictiva.
- Relevante.
- Accionable.
- Genuina.
- MSignificativa.
- Prcisa (Precisa).
- Oportuna.
- Independiente.
- Coste-Rentable.

La matriz detallada de evaluación para cada métrica se recoge en el documento “Matriz de Evaluación PRAGMATIC Completa”.